

نطاق معيار PCI DSS وتحديد نموذج التقييم الذاتي SAQ (Moyasar)

القسم 04-compliance-memo الحالة draft المالك Founder آخر تحديث 18-08-2026

الغرض. توثيق وتحديد نطاق تدفقات الدفع بالبطاقات في فلاي قাকা (Fly GACA) الخاضعة لمعيار PCI DSS، وتحديد نموذج التقييم الذاتي (SAQ) الواجب تطبيقه، والالتزامات السارية حالياً، لتضمينها في استبيانات أمن B2B وملفات العناية الواجبة للمستثمرين.

المكانة التنظيمية. معيار PCI DSS هو معيار تعاقدى لشبكات البطاقات الائتمانية وليس قانوناً سعودياً. يعمل بجانب نظام حماية البيانات الشخصية (PDPL) ومتطلبات هيئة الزكاة والضريبة والجمارك (ZATCA) دون الإخلال بهما.

1. آلية عمل الدفع الفعلية

- متحقق منها من خلال الشيفرة البرمجية المشحونة (FlyGACA-app/src/pages/checkout/Checkout.tsx):
- صفحة `/checkout` هي صفحة تخدمها فلاي قাকা من نطاقها الخاص.
 - تقوم الصفحة بـ الحقن الديناميكي لعنصر واجهة دفع ميسر (Moyasar Payment Form widget) — عبر `https://cdn.moyasar.com/mpf/1.16.0/moyasar.js` وملف الأنماط التابع له.
 - يتم تثبيت عنصر الواجهة داخل عقدة DOM في الصفحة (`#moyasar-checkout-form`).
 - يُدخل حامل البطاقة بيانات بطاقته أو مدى أو Apple Pay داخل عنصر الواجهة مباشرة؛ وتُرسل تلك البيانات من المتصفح مباشرة إلى ميسر (`api.moyasar.com`).
 - تعيد ميسر توجيه المستخدم مع `?id=<paymentId>` : ويتحقق الخادم من صحة الدفع عبر اتصال خادم-إلى-خادم (Server-to-Server).
- لا يتم نقل أو معالجة أو تخزين أي من بيانات حاملي البطاقات على خوادم فلاي قাকা أو Firestore أو في أي سجلات للشركة. وتتم مشتريات iOS عبر Apple IAP / RevenueCat وهي خارج نطاق معيار PCI بالكامل.

2. مسألة تحديد نوع نموذج SAQ

أهلية نموذج SAQ A تعتمد على بنية التكامل البرمجي وليس فقط على عدم تخزين بيانات البطاقات:

- نموذج SAQ A البسيط مخصص للتجار الذين يفوضون صفحة الدفع بالكامل — مثل إعادة التوجيه الكامل (Full redirect) للمزود، أو استخدام `iframe` لا يمكن للتاجر التأثير في محتواه.
- تكاملاً يعتمد على تضمين جافاسكربت داخل صفحة نخدمها ونتحكم بها. وعليه فإن التاجر مسؤول عن سلامة وتكامل النصوص البرمجية (Scripts) في الصفحة لمنع هجمات اعتراض البيانات (Magecart).

[إجراء مطلوب من المالك] يجب تأكيد نوع SAQ المعتمد مع شركة ميسر والبنك المستحوذ — فقد يكون SAQ A مع معايير سلامة النصوص، أو SAQ A-EP.

3. الالتزامات السارية بموجب PCI DSS v4.0.1

المتطلب	ما يطلبه	وضعنا الحالي
6.4.3	الاحتفاظ بقائمة حصر لكل نص برمجي في صفحة الدفع؛ واعتماده؛ وضمان سلامته	فجوة. لا توجد قائمة حصر. يُحقن سكربت ميسر في وقت التشغيل دون سمة التحقق من تكامل الموارد (SRI)
11.6.1	كشف التعديلات غير المصرح بها على ترويسات ومحتوى صفحة الدفع والتنبيه عنها	فجوة. لا توجد آلية مفعلة لكشف التلاعب

4. مطابقة سياسات أمان المحتوى (CSP)

تحدد فلاي قاكا سياسة أمان المحتوى (CSP) في أربعة مواقع، ويجب توحيدها ومطابقتها لضمان موثوقية وأمان صفحة الدفع.

5. بيان النطاق المعتمد

لا تقوم فلاي قاكا بتخزين أو معالجة أو نقل بيانات حاملي البطاقات. يتم التقاط بيانات الدفع عبر واجهة دفع مستضافة من ميسر ونقلها مباشرة من متصفح العميل إلى شركة ميسر المرخصة والممثلة لمعيار PCI DSS. تقتصر أنظمة فلاي قاكا على استلام معرف الدفع وحالته، وتحمل مسؤولية سلامة وتكامل صفحة الدفع والسكربتات المحملة عليها.

وثائق ذات صلة: `cyber-risk-assessment-2026-08.md`، `isms-scope-and-statement-of-applicability.md`، `03-finance/monetization.md`